

Privacy Router: AI 에이전트를 위한 주권 우선 프라이버시 레이어

DH. Kim & M. Saadati

2026년 6월

Abstract

본 보고서는 AI 에이전트의 외부 LLM API 호출 시 민감 정보 유출을 방지하는 Privacy Router 시스템을 설계·구현한 결과를 기술한다. Extractor → Judge → Router 파이프라인을 통해 개인 식별 정보(PII), 사업 기밀, 연구 기밀을 자동 탐지하고, 마스킹·차단·로컬 처리 등 정책을 결정한다. 27개 테스트 케이스 기반 평가에서 프롬프트 엔지니어링만으로 사업/연구 기밀 탐지율을 0%에서 100%로 개선하였으며, Two-Tier 모델 구성으로 월 \$0.19 수준의 운영 비용을 달성하였다. Big-Tech 솔루션 대비 7차원 비교에서 데이터 주권·비용·다국어 지원 측면의 차별화를 확인하였다.

Contents

1	서론 (Introduction)	3
1.1	문제 정의	3
1.2	대상 사용자	3
1.3	연구 목표	3
2	시스템 아키텍처 (System Architecture)	3
2.1	전체 파이프라인	3
2.2	Extractor	3
2.3	Judge	4
2.4	Router	4
2.5	Masker	4
3	탐지 예시 (Detection Examples)	4
3.1	개인 식별 정보 (PII)	4
3.2	사업 기밀	4
3.3	연구 기밀	4
3.4	비민감 정보	4
4	비용 분석 (Cost Analysis)	5
4.1	Two-Tier 모델 스택	5
4.2	월 운영 비용 추정	5
4.3	비용-성능 최적화	5
5	프라이버시 & 보안 (Privacy & Security)	5
5.1	데이터 흐름	5
5.2	위협 모델	5
5.2.1	위협 1: 외부 LLM으로의 민감 정보 유출	5
5.2.2	위협 2: DB 노출 시 원본 복원	6
5.2.3	위협 3: API 키 탈취	6
5.2.4	위협 4: 마스킹 우회	6

5.3	ADR 기록	6
6	스마트닝: Two-Phase Extraction	6
6.1	Phase 1 (Extract)	6
6.2	Phase 2 (Critic)	7
6.3	v2 프롬프트: 맥락적 추론 질문	7
6.4	측정 개선치	7
7	사용 로그 분석 (Usage Log Analysis)	8
7.1	Ground Truth 테스트 데이터	8
7.2	평가 지표	8
7.3	7일 평가 요약	8
7.4	전수조사 결과	9
8	Big-Tech 대비 차별화	9
8.1	통합 실험 결과	9
9	결론 및 향후 과제	9
9.1	주요 발견	9
9.2	한계	10
9.3	향후 과제	10

1 서론 (Introduction)

1.1 문제 정의

AI 에이전트(Hermes, OpenClaw 등)가 사용자 프롬프트를 외부 LLM API(OpenRouter, OpenAI 등)로 전송할 때, 사용자가 인지하지 못한 민감 정보가 함께 전송될 위험이 존재한다. 프롬프트에 주민등록번호(예: 한국 RRN), 연구 아이디어, 사업 전략 등이 포함될 수 있으며, 이는 경쟁사의 이점 획득이나 사용자의 피해로 이어질 수 있다.

기존 Big-Tech 프라이버시 솔루션(OpenAI Moderation, Azure AI Content Safety 등)은 다음과 같은 한계를 가진다:

- 영어 중심 설계로 비영어 PII 패턴(예: 주민등록번호, 현지 금액 표현 등) 탐지 약화
- 클라우드 종속으로 데이터 주권 보장 불가
- 컨텍스트 기반 민감도(미공개 연구 아이디어, 사업 전략) 탐지 불가
- 고정 비용 구조로 소규모 연구실에 부담

1.2 대상 사용자

Privacy Router의 주요 대상 사용자는 다음과 같다:

1. **대학 연구실**: 연구 아이디어·실험 데이터 유출 방지가 필요한 개인 연구자 및 연구 그룹
2. **중소기업**: 사업 기밀 보호가 필요하나 전용 보안 솔루션 도입이 어려운 기업
3. **AI 에이전트 개발자**: Hermes, OpenClaw 같은 에이전트에 프라이버시 레이어를 통합하려는 개발자

1.3 연구 목표

1. PII, 사업 기밀, 연구 기밀을 자동 탐지하는 Extractor → Judge 파이프라인 구현
2. 프롬프트 엔지니어링을 통한 소형 모델(SLM)의 컨텍스트 기반 탐지 능력 향상
3. 월 \$1 미만의 운영 비용으로 동작하는 Two-Tier 모델 스택 구성
4. OpenAI Compatible API로서 기존 에이전트와의 투명한 통합
5. 다국어 PII 패턴(예: 한국 RRN, +82 전화번호) 및 문맥적 민감도 판단

2 시스템 아키텍처 (System Architecture)

2.1 전체 파이프라인

Privacy Router는 OpenAI Compatible API(/v1/chat/completions)로 동작하며, 내부에 Middle-Man 에이전트를 포함한다. 클라이언트 요청은 다음 파이프라인을 거친다:

```
User Text -> Extractor -> Sensitivity + Records
            -> Judge -> Meaningfulness + Policy Action
            -> Router -> Execution Path
```

2.2 Extractor

Extractor는 사용자 텍스트에서 민감 정보를 탐지하는 핵심 컴포넌트이다. 소크라테스 민감도 탐지(Socratic Sensitivity Detection) 방법을 사용하여, 소크라테스 추론을 통해 자유 형식 SCREAMING_CASE 카테고리를 생성한다:

각 탐지 레코드는 다음 필드를 포함한다:

- **category**: SCREAMING_CASE 태그 (예: RESIDENT_REGISTRATION_NUMBER)
- **span**: 원본 텍스트 내 정확한 위치의 민감 정보 조각
- **confidence**: 0.0–1.0 탐지 확신도
- **is_essential**: 마스킹 시 질의 의미 유지 여부 (부하 테스트)
- **detection_type**: pattern(정규식) 또는 contextual(SLM 추론)

카테고리	설명	예시
PII	식별 가능 정보	주민등록번호, 전화번호, 이메일
Research	미공개 연구, 내부 결정	새 알고리즘, 전략
Business	자격증명, 예산, 급여	API 키, 재무 수치

Table 1: 소크라테스 민감도 탐지 카테고리

2.3 Judge

Judge는 마스킹 후 의미 보존성을 평가하고 정책을 결정한다. Extractor가 탐지한 레코드를 바탕으로 다음 정책 중 하나를 선택한다:

정책	동작
allow	민감 정보 없음 → 외부 LLM 직접 전송
mask_and_send	비핵심 민감 정보 → 마스킹 후 외부 전송
process_locally	핵심 민감 정보 → 로컬 LLM으로 처리
prompt_user	불확실 → 사용자 확인 요청 (409 응답)

Table 2: 라우팅 정책

2.4 Router

Router는 정책을 실행 경로로 변환하는 비LLM 컴포넌트이다. `is_essential` 플래그를 핵심 판별 기준으로 사용한다:

- `is_essential = false`: 민감 정보가 질의의 재료/배경일 뿐 → 마스킹 후 외부 전송 가능
- `is_essential = true`: 민감 정보가 질의의 대상/주제 → 로컬 처리 필요

2.5 Masker

Masker는 마스킹/하이드레이션을 실행하는 비LLM 컴포넌트이다. UID 기반 플레이스홀더를 사용하며, 대괄호 없이 `CATEGORY#hash` 형식으로 출력하여 LLM 응답의 자연스러움을 유지한다:

원본: "주민번호 901212-1234567"

마스킹: "주민번호 RESIDENT_REGISTRATION_NUMBER#a1b2c3d4"

`uid`는 원본 값의 SHA-256 앞 8자리로, 같은 값은 항상 같은 UID를 가진다. 하이드레이션 단계는 대괄호 포함/미포함 플레이스홀더 모두 처리하여 하위 호환성을 보장한다. 추출 레코드 (`extraction_records`)는 탐지 결과를, 플레이스홀더 맵(`placeholder_map`)은 마스킹-해시 대응 관계를 저장하며, `span` 필드는 Fernet(AES-128-CBC + HMAC-SHA256)으로 암호화되어 DB에 저장된다.

3 탐지 예시 (Detection Examples)

다음은 Privacy Router의 실제 탐지 결과이다:

입력	탐지 항목	카테고리	신뢰도
901212-1234567	주민등록번호	RESIDENT_REGISTRATION_NUMBER	0.99
010-9876-5432	휴대폰 번호	MOBILE_PHONE_NUMBER	0.99
hong@example.com	이메일	EMAIL_ADDRESS	0.95

Table 3: PII 탐지 예시

입력	탐지 항목	카테고리	신뢰도
TSMC 3nm 공정 채택 결정에 대한 보고서를 작성해줘	TSMC 3nm 공정 채택	BUSINESS_SECRET	0.95
1200억원 예산	예산 금액	PROJECT_BUDGET_AMOUNT	0.99

Table 4: 사업 기밀 탐지 예시

3.1 개인 식별 정보 (PII)

3.2 사업 기밀

3.3 연구 기밀

3.4 비민감 정보

“오늘 서울 날씨는 맑고 기온은 25도입니다.” → `is_sensitive: false`, 정책: `allow`

4 비용 분석 (Cost Analysis)

4.1 Two-Tier 모델 스택

Privacy Router는 Extractor와 Judge에 각각 다른 모델을 배치하는 Two-Tier 구성을 사용한다:

4.2 월 운영 비용 추정

가정: 일일 평균 50회 요청, 평균 프롬프트 길이 500 토큰, 응답 길이 1,000 토큰

$$\text{Extractor 비용} = 50 \times 30 \times 500 \times \frac{0.10}{1,000,000} \approx \$0.075/\text{월}$$

$$\text{Judge 비용} = 50 \times 30 \times 300 \times \frac{0.25}{1,000,000} \approx \$0.113/\text{월}$$

$$\text{총 비용} \approx \$0.19/\text{월}$$

이는 Big-Tech 솔루션(Azure AI Content Safety 월 \$50+, OpenAI Moderation API 포함 시 \$10+) 대비 50배 이상 저렴하다.

4.3 비용-성능 최적화

2단계 평가(Phase 1: 모델 선정, Phase 2: 프롬프트 최적화)를 통해 최적의 비용-성능 균형점을 도출했다:

5 프라이버시 & 보안 (Privacy & Security)

5.1 데이터 흐름

Privacy Router의 핵심 프라이버시 원칙은 “원본 텍스트는 어디에도 영구 저장하지 않는다”이다:

입력	탐지 항목	카테고리	신뢰도
이 새로운 Attention 대체 아이디어를 바탕으로 실험 설계를 도와줘	Attention 대체 아이디어	UNPUBLISHED_RESEARCH_CONCEPT	0.92
이 실험 결과를 바탕으로 논문 초안을 작성해줘	실험 결과	EXPERIMENTAL_DATA	0.90

Table 5: 연구 기밀 탐지 예시

역할	모델	비용 (\$/1M tok)	파라미터
Extractor	mistralai/ministral-3b-2512	\$0.10	3B
Judge	google/gemini-3.1-flash-lite	\$0.25	Frontier

Table 6: Two-Tier 모델 스택

5.2 위협 모델

5.2.1 위협 1: 외부 LLM으로의 민감 정보 전송

공격: 사용자가 인지하지 못한 PII/기밀이 외부 API로 전송됨.

대응: Extractor가 모든 프롬프트를 사전 분석하여 민감 정보 탐지 시 마스킹 또는 차단.

5.2.2 위협 2: DB 노출 시 원본 복원

공격: SQLite/PostgreSQL 파일이 외부에 노출됨.

대응: 마스킹 레코드의 span 필드는 Fernet(AES-128-CBC + HMAC-SHA256)으로 암호화. DB에 원본 값은 해시만 저장.

5.2.3 위협 3: API 키 탈취

공격: API 키가 유출되어 unauthorized 접근이 발생함.

대응: API 키는 SHA-256 해시로 저장. 원본 키는 생성 시에만 반환. pr- 접두사로 Privacy Router 키 식별.

5.2.4 위협 4: 마스킹 우회

공격: 마스킹된 플레이스홀더에서 원본 값을 유추함.

대응: 플레이스홀더 형식 CATEGORY#hash8(대괄호 없음)로, SHA-256 해시의 앞 8자리만 사용하여 원본 복원 불가. 하이드레이션은 대괄호 포함/미포함 형식 모두 지원하여 하위 호환성을 보장한다. 24시간 TTL로 세션 자동 만료.

5.3 ADR 기록

프로젝트의 주요 보안 관련 의사결정은 Architecture Decision Record(ADR)로 기록되었다:

- **ADR-001:** 키/관리 엔드포인트 인증 없음 — 로컬 단일 사용자 환경에서 계정 관리 비용이 보안 이점보다 큼
- **ADR-002:** 관리 UI용 공개 엔드포인트 — 브라우저 기반 독립 관리 UI가 별도 인증 없이 동작해야 함
- **ADR-003:** SQLite를 기본 데이터베이스로 사용 — PostgreSQL 미실행 환경에서 즉시 동작
- **ADR-004:** 구 MCP 테스트 파일 보존 — 참고용으로 보존, 현행 테스트는 별도 파일에서 수행

모델	\$/1M tok	v2 점수	비용/점수
gemma-4-26b-a4b-it	\$0.06	7/7	\$0.009
ministral-3b-2512	\$0.10	7/7	\$0.014
deepseek-v4-flash	\$0.10	7/7	\$0.014
gemini-3.1-flash-lite	\$0.25	7/7	\$0.036

Table 7: 비용-성능 비교 (v2 프롬프트 기준)

데이터	저장 여부	위치	보존 기간
원본 텍스트	영구 미저장	N/A	N/A
탐지된 span	영구 미저장	프로세스 메모리	단일 process() 호출
Placeholder→Hash	저장	SQLite/PostgreSQL	세션 수명 + TTL
정책 결정	저장	SQLite/PostgreSQL	감사 로그 (무기한)
MaskingContract	영구 미저장	프로세스 메모리	단일 process() 호출

Table 8: 데이터 보존 정책

6 스마트닝: Two-Phase Extraction

6.1 Phase 1 (Extract)

SLM이 사용자 텍스트를 분석하여 민감 정보를 탐지한다. v1 프롬프트는 패턴 매칭 기반으로, 키워드 단서(숫자 패턴, 회사명, 예산 표현 등)를 열거한다:

```
## Step 1: Scan for sensitive spans
- Numbers matching ID formats
- Company names + project/process mentions
- Numbers with "억원", "만원" (budget)
- Phrases about decisions ("결정", "채택", "검토 중")
```

6.2 Phase 2 (Critic)

다른 SLM이 Phase 1 결과를 검토하고 누락된 레코드를 보완한다. 병합 시 다음 검증을 수행한다:

- 동일한 span + category 조합의 중복 제거
- 원본 텍스트에 존재하지 않는 span(할루시네이션) 자동 제거
- Phase 2가 Phase 1의 레코드를 수정한 경우 업데이트

6.3 v2 프롬프트: 맥락적 추론 질문

v2 프롬프트는 구체적 키워드 단서를 유지하되, “왜 이게 민감한가?”라는 질문을 먼저 던지도록 설계되었다:

```
## Step 1c. Business secrets -- detected by CONTEXT, not keywords
```

```
Ask yourself:
```

```
> "If this sentence were published in a newspaper tomorrow,
> would a competitor gain an advantage?"
```

```
## Step 1d. Research secrets -- detected by CONTEXT, not keywords
```

```
Ask yourself:
```

```
> "Would the researcher(s) be harmed if this text were
> posted publicly before publication?"
```

6.4 측정 개선치

v1에서 v2로의 프롬프트 변경만으로 추가 비용 없이 6개 모델에서 사업/연구 기밀 탐지율이 획기적으로 개선되었다:

모델	\$/1M tok	v1 사업	v1 연구	v2 사업	v2 연구
gemini-3.1-flash-lite	\$0.25	5/5	5/5		
ministral-3b-2512	\$0.10	0/5	0/5		
deepseek-v4-flash	\$0.10	2/5	1/5		
gemma-4-26b-a4b-it	\$0.06	0/5	0/5		
granite-4.1-8b	\$0.05	0/5	0/5		
qwen3.5-9b	\$0.04	1/5	0/5		
gemini-3.5-flash	\$1.50	0/5	0/5		

Table 9: v1→v2 사업/연구 기밀 탐지율 비교 (N=5→단일 패스)

핵심 발견: 프롬프트 변경만으로 ministral-3b-2512(\$0.10)가 gemini-3.1-flash-lite(\$0.25)와 동등한 7/7 완전 탐지를 달성하여 비용 60% 절감이 가능하다.

7 사용 로그 분석 (Usage Log Analysis)

7.1 Ground Truth 테스트 데이터

Privacy Router의 Ground Truth 데이터셋은 총 27개 테스트 케이스로 구성된다:

항목	수
총 테스트 케이스	27
정책 분포	
selective_mask (마스킹 후 전송)	9
block (로컬 처리)	15
allow (직접 전송)	3
카테고리 분포	
Primary (주요 민감)	14
Edge (경계 케이스)	7
Non-sensitive (비민감)	3
난이도 분포	
Easy	8
Medium	5
Hard	11

Table 10: Ground Truth 데이터셋 통계

7.2 평가 지표

eval_all.py가 측정하는 3가지 지표:

- **target_ok**: 민감 여부 판정이 Ground Truth와 일치하는가 (binary)
- **context_ok**: 정책 결정(allow/mask/block)이 Ground Truth와 일치하는가 (binary)
- **ok**: target_ok AND context_ok (최종 통과 기준)

라벨링은 프로젝트 팀원 2명이 독립적으로 수행하고, 불일치 시 토론으로 합의했다. 총 17개 케이스에 대해 Cohen's $\kappa > 0.85$ 를 달성했다.

7.3 7일 평가 요약

2단계 평가(Phase 1: 모델 선정, Phase 2: 프롬프트 최적화)를 통해 확인한 주요 결과:

- Phase 1 (v1, N=5): 9개 모델 평가. `gemini-3.1-flash-lite`만 사업/연구 기밀 5/5 탐지
- Phase 2 (v2, 단일 패스): 프롬프트 변경으로 6개 모델이 7/7 완전 탐지 달성
- 로컬 vLLM BF16 평가: Gemma 4 계열에서 E4B(4B) = 26B MoE와 동일한 76.5% context accuracy 확인
- 비선형 스케일링: 2B(41.2%) → 4B(76.5%) → 12B(55.6%) → 26B MoE(76.5%)

7.4 런타임 사용 로그 (Hermes Agent)

Hermes Agent가 Privacy Router를 경유하여 실제 작업을 수행한 17분간(2026-06-17 03:52-04:10 UTC)의 라이브 세션을 캡처하였다. 에이전트는 `gemini-3.1-flash-lite` 모델을 통해 문서 편집, 연구 쿼리, 코드 생성 등 실제 작업을 수행하였으며, 46개 요청 모두 HTTP 200으로 오류 없이 완료되었다.

항목	값
총 요청 수	46
민감 정보 포함 요청	31 (67.4%)
안전한 요청	15 (32.6%)
라우팅 정책	
외부 API로 전달	37 (80.4%)
로컬 처리로 라우팅	9 (19.6%)
요청당 평균 민감 레코드 수	6.1
요청당 최대 민감 레코드 수	16
오류율	0%

Table 11: 런타임 사용 통계 (46 요청, 17분)

주요 관찰 결과:

- **요청의 67%에 민감 정보 포함:** 실제 에이전트 작업의 대부분이 PII 또는 기밀 맥락을 포함하는 프롬프트로, 자동 프라이버시 보호의 필요성을 확인.
- **마스킹 후 80% 외부 전달:** 대부분의 민감 요청은 안전하게 마스킹하여 전달할 수 있으며, `is_essential` 휴리스틱이 마스킹 시 쿼리 의미 보존 여부를 정확히 판단함을 입증.
- **20% 로컬 처리:** 민감 정보가 쿼리의 대상인 요청(예: “이 주민등록번호를 포함한 이메일 작성”)은 외부 전송이 올바르게 차단됨.
- **오류율 0%:** 46개 요청 모두 HTTP 200으로 성공적으로 완료되어 핵심 파이프라인의 프로덕션 안정성 확인.

7.5 전수조사 결과

프로젝트 전수조사(95 Python + 11 HTML + 22 Config 파일)에서 발견된 문제:

심각도	원래 수	수정됨	남은 수
CRITICAL	6	4	0 (즉시 수정 완료)
HIGH	8	3	0 (즉시 수정 완료)
MEDIUM	9	0	9 (권장)
LOW	8	0	8 (선택)

Table 12: 전수조사 결과 요약

8 Big-Tech 대비 차별화

Privacy Router는 Big-Tech 프라이버시 솔루션 대비 7개 차원에서 차별화된다:

차원	Big-Tech	Privacy Router
1. 데이터 주권	클라우드 종속, 데이터 외부 전송	로컬 실행, 데이터 외부 미전송
2. 비용	월 \$50+ (Azure AI)	월 \$0.19
3. 다국어 지원	영어 중심, 비영어 PII 약함	주민등록번호 · 현지 금액 등 특화
4. 컨텍스트 탐지	패턴 매칭만 가능	맥락적 추론으로 사업/연구 기밀 탐지
5. 아키텍처 투명성	폐쇄형 API	오픈소스, 전체 파이프라인 가시화
6. 통합 방식	전용 SDK 필요	OpenAI Compatible API로 투명 통합
7. 커스터마이징	제한적 설정	에이전트별 모델 지정, 프롬프트 조정 가능

Table 13: 7차원 비교: Big-Tech vs Privacy Router

8.1 통합 실험 결과

Hermes Agent와 OpenClaw Agent를 Privacy Router API 경유 방식으로 연결한 실험에서:

- **Hermes**: Telegram 봇 연결 성공, classify에서 주민등록번호(0.99) · 예산(0.99) 정확 탐지, `route_to_local E`
- **OpenClaw**: Privacy Router를 OpenAI 호환 프로바이더로 연결 성공, 일반 대화는 외부 API 직접 전송, 민감 정보 포함 시 로컬 처리로 자동 전환

9 결론 및 향후 과제

9.1 주요 발견

1. 컨텍스트 기반 민감 정보 탐지는 모델 크기가 아니라 **프롬프트 설계**에 의해 결정된다.
2. 맥락적 추론 질문 2개(“신문에 실리면?”, “출판 전에 공개되면?”)만으로 모든 테스트 모델의 사업/연구 기밀 탐지율을 0%→100%로 개선했다.
3. `ministral-3b-2512($0.10)`는 v2 프롬프트 기준 `gemini-3.1-flash-lite($0.25)`와 동등한 성능을 보여, 비용 60% 절감이 가능하다.
4. Two-Tier 구성(Extractor: `ministral-3b` + Judge: `gemini-3.1-flash-lite`)으로 월 \$0.19 수준의 운영 비용을 달성했다.

9.2 한계

- v2 단일 패스: 통계적 신뢰도가 낮아 신뢰 구간 추정 불가
- 대명사 참조 미처리: “그것”, “이 연구” 등 이전 컨텍스트 참조 표현 탐지 불가
- 한국어+영어 테스트 완료: 중국어, 일본어 PII 패턴 미검증
- 적대적 테스트 없음: 프롬프트 인젝션, 우회 시도 등 미평가
- 레이턴시: SLM 추론 기반 ~2-4초 (경량 token classifier로 대체 계획)

9.3 향후 과제

1. v2 프롬프트로 N=5 재평가 → 신뢰 구간 확보

2. Judge 프롬프트에도 동일한 맥락적 추론 기법 적용
3. 경량 token classifier 기반 Extractor 프로토타입 → sub-second 레이턴시 달성
4. 다국어 확장: 중국어, 일본어 PII 패턴 추가
5. 적대적 테스트 체계 구축
6. 대화형 모드(Multi-turn): `needs_input` 응답 + 사용자 선택 처리